课程编号：

《开源创新思维》
平时作业报告

姓　　名	杨美玲	学　　号	f25011412
班　　级	f250118	指　导　教　师	祝欣蓉
开　设　学　期	2026-2027 秋 季 学 期		
开　设　时　间	第 1 周 — — 第 16 周		
报　告　日　期	2026 年 10 月 29 日		
评　定　成　绩		评　定　人	祝欣蓉
		评　定　日　期	

上海杉达学院

1、开源项目介绍

Apache Commons Text（以下简称 commons-text）是 Apache 软件基金会（ASF）Commons 项目下的一个通用 Java 文本处理类库，定位类似“字符串版的 Commons Lang”。它把开发中反复出现的文本处理需求沉淀为一组小而精的 API，主要能力包括：字符串相似度与编辑距离计算（Levenshtein、Jaro-Winkler、Cosine 等）、大小写与空白/引号转换、HTML、XML、Java、CSV、JSON 等格式的转义与反转义、文本分词与插值替换（StringSubstitutor）、文本差异比较（diff）、随机字符串生成等。

扫描对象为该项目 GitHub 官方仓库 apache/commons-text 的 master 分支（https://github.com/apache/commons-text），以 git clone --depth 1 方式获取，本地体积约 4.5 MB。仓库根目录 LICENSE.txt 声明整体采用 Apache License 2.0，NOTICE.txt 声明版权归 The Apache Software Foundation，构建工具为 Maven，工程坐标为 org.apache.commons:commons-text:1.15.1-SNAPSHOT。

规模统计：仓库共 276 个文件、52 个目录；其中 Java 源文件 220 个（src/main/java 113 个、src/test/java 107 个），Java 代码约 5.5 万行；其余为 Maven 构建配置（pom.xml、assembly 描述）、代码质量配置（checkstyle、spotbugs）、GitHub Actions 流水线（.github/workflows）、站点与文档资源（src/site）以及测试数据（CSV 语料、OSS-Fuzz 用例、图片等）。

选择该项目的理由有三点：一是规模适中，一次完整扫描仅需一分钟左右，便于复现与对比；二是作为 ASF 项目，源文件普遍带规范化的许可证头，可以作为“许可证声明规范”的样本；三是仓库中同时存在源码、构建脚本、文档、图片等异质文件，能较真实地反映扫描工具在不同文件类型上的识别能力与盲区。

2、许可证合规工具的选择与安装

依据《33 款开源软件许可合规工具-逐条优缺点与选型手册》的“学生选型速查表”，“课程作业：扫一遍代码里的许可证”对应的首选工具为 ScanCode Toolkit，评星三星；其定位是“业界事实标准的开源代码扫描引擎”，优点是识别最准（许可证、版权、包清单、依赖）、支持 JSON/HTML/CSV/SPDX 多种输出、易于接入 CI/CD。手册最后的“组合建议”也以 ScanCode 作为主力扫描器。

其余工具在本场景下不合适：Fossology 需部署 PostgreSQL 并采用上传式扫描，个人单次扫描成本过高；FOSSLight 是一体化平台、AGPL 许可且部分文档为韩文；ORT 属于端到端流水线，配置项多、学习曲线陡；Tern 只面向容器镜像；Apache Rat 仅检查许可证头、不做成分分析；OSS Attribution Builder 不执行扫描。因此最终选定 ScanCode Toolkit 32.5.0（Apache-2.0）。

安装环境为 Windows 11 + Python 3.13。为避免污染系统环境，先在项目目录下建立独立虚拟环境，再安装并验证版本：

```
python -m venv .venv-scancode
```

```
.venv-scancode\Scripts\python -m pip install scancode-toolkit
```

```
.venv-scancode\Scripts\scancode --version
```

版本输出为 ScanCode 32.5.0、ScanCode Output Format 4.1.0、SPDX License List 3.27，说明许可证库与输出格式版本均已就绪。

问题一：官方源下载过慢。

工具主包体积 120.4 MB，直连 PyPI 实测速率仅约 26 KB/s，按此速度需要一小时以上，且中途多次重试。改用腾讯云 PyPI 镜像（-i https://mirrors.cloud.tencent.com/pypi/simple）后速率提升到 1 MB/s 以上，连同 70 余个依赖在内约 4 分钟安装完成。

问题二：插件框架版本不兼容。

安装结束后执行 scancode --version 直接报错，抛出 ValueError: did not find any "pre_scan" hooks，原因是 pip 自动安装的最新版 pluggy 1.7.0 与 plugincode 32.0.0 不兼容。执行 pip install "pluggy<1.6" 将其降级到 1.5.0 后，命令恢复正常。这提示：pip 解析出的“最新依赖”未必可用，必要时须手动锁定版本。

问题三：多进程下出现文件超时。

首轮扫描使用默认参数（23 个进程、单文件 120 秒超时），结果有 5 个文件扫描失败：README.md、CODE_OF_CONDUCT.md、NOTICE.txt、RELEASE-NOTES.txt 与 release-notes.vm，全部报 Processing interrupted: timeout after 120 seconds。值得注意的是 NOTICE.txt 仅 179 字节也超时，单独重扫时只用 10 秒即完成，说明超时并非文件本身过大，而是进程数远超 CPU 核数导致的争抢。把并发进程数降为 4、单文件超时提高到 600 秒后重扫，5 个文件全部成功，错误数归零；扫描速度反而由 2.02 文件/秒提升到 4.36 文件/秒，总耗时从 142 秒降到 67 秒。

问题四：首次运行需重建索引。

首次执行时出现 Inconsistent License cache: rebuilding index 提示，工具自动重建内置许可证索引，额外耗时约 3.2 秒；此外在 Windows 下必须使用虚拟环境内 Scripts\scancode.exe 的完整路径（或先激活虚拟环境），否则会提示找不到命令。

3、工具输出的检测报告

最终采用的扫描命令如下，同时输出机器可读的 JSON 与可视化 HTML 报告，后续统计均基于 JSON 结果：

```
scancode --license --copyright --package --timeout 600 --processes 4 \
```

```
        --json-pp scancode-result.json --html scancode-result.html commons-text
```

总体规模与识别率：共扫描 328 个资源（276 个文件、52 个目录），总耗时 67 秒（其中许可证匹配 63 秒），错误 0。276 个文件中有 267 个识别出许可证声明，识别率 96.7%，未识别 9 个（3.3%）。工具还从 pom.xml 中解析出 Maven 包 commons-text

1.15.1-SNAPSHOT 及 14 条依赖坐标（commons-lang3 3.21.0、commons-io 2.22.0、JUnit 5、Mockito 4.11.0、JMH 1.37 等，其中绝大多数为测试范围）。

按许可证表达式统计的文件分布见表 1。可以看出 Apache-2.0 覆盖了全部被识别文件，仅有 3 个文件出现复合表达式（即在 Apache-2.0 之外还命中其他条目）。

表 1 许可证表达式与文件数分布

许可证表达式	文件数	占全部文件比例
Apache-2.0（仅此一项）	264	95.7%
Apache-2.0 + Generic CLA	2	0.7%
Apache-2.0 + GPL-1.0+ + GPL-2.0 + Classpath-exception	1	0.4%
未识别出许可证	9	3.3%
合计	276	100%

未识别许可证的 9 个文件按类型分布为：PNG 图片 3 个、XCF（GIMP 源文件）2 个、无扩展名的 OSS-Fuzz 测试用例 2 个、下载页脚本 download_text.cgi 1 个、测试数据 stringEscapeUtilsTestData.txt 1 个，见图 1。

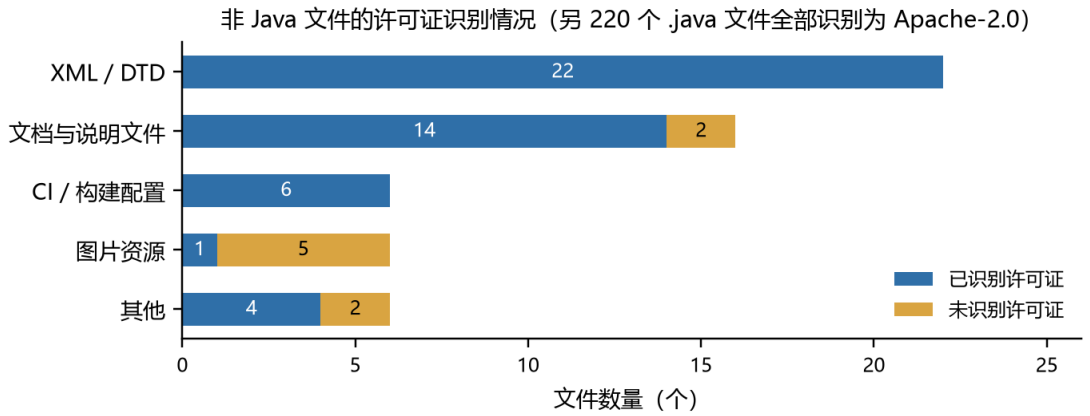


图 1 各类型文件的许可证识别情况

4、检测报告的详细分析

（一）许可证构成：单一授权、声明一致。

267 个文件的每一次命中都指向 apache-2.0，其中 264 个文件只含这一项；匹配算法全部为 2-aho（Aho-Corasick 多模式串匹配），匹配得分 100，命中规则以 apache-2.0_663.RULE 为主。这与 ASF 的强制要求一致——所有进入 ASF 仓库的源文件都必须在文件头声明 ASF 版权与 Apache-2.0 授权。因此从成分分析角度看，该项目不存在许可证混用或 Copyleft 传染的风险，属于典型的“单一许可证、高一致性”仓库。

（二）三处复合表达式的判定。

CONTRIBUTING.md 与 README.md 命中了 generic-cla。这两处的原文是“贡献者许可协议（CLA）”的说明文字，属于社区治理文本而非代码授权声明；其中 README.md 第 96 行的匹配得分仅 80 分，明显低于满分的强匹配，属于应当人工降权的文本级匹配。lcs-perf-analysis-inputs.csv 则命中了 gpl-1.0-plus、gpl-2.0 与 classpath-

exception-2.0，是本报告最典型的一处误报：该文件是 LCS（最长公共子序列）性能测试的输入语料，第 18 行是一段 Lorem ipsum 拉丁文填充文字（源自古罗马西塞罗的著作），因句式与 GPL 序言高度相似，被四条规则以 100 分命中。从语义看这段文字不含任何授权意思表示，不应视为引入了 GPL 代码。此例恰好印证了手册中的“误区三：扫完就等于合规了”——即使匹配得分是 100，也必须结合上下文人工确认。

（三）未识别文件的性质。

9 个未识别文件可归为三类：一是图片与设计源文件（PNG 3 个、XCF 2 个），属于二进制资源，文本匹配天然无法生效；二是无扩展名的 OSS-Fuzz 测试用例 2 个，是模糊测试自动生成的二进制输入，并非人类可读代码；三是站点脚本与测试数据 2 个，确实不含许可证头。ASF 采用“根目录 LICENSE.txt 统一覆盖全仓”的声明方式，上述文件都不是独立分发单元，因此不构成合规缺陷；但若下游把仓库内容重新打包对外分发，仍需确保 LICENSE 与 NOTICE 随包提供。

（四）版权识别的局限。

全仓 276 个文件中仅识别出 1 条版权声明（Copyright 2014-2026 The Apache Software Foundation，位于 NOTICE.txt），版权持有人统计同样只有 The Apache Software Foundation 一项。这不是工具失效，而是 ASF 的通行做法：源文件头只写授权声明、不写版权行，版权集中体现在 NOTICE 文件中。因此制作 SBOM 时不能只看版权识别结果，必须同时读取 LICENSE/NOTICE 与包元数据（本次已成功解析出 Maven 坐标与 14 条依赖）。

（五）合规结论与建议。

合规判定：本项目为单一 Apache-2.0 项目，无 Copyleft 污染、无第三方许可证混入，合规风险低，可直接用于商业产品。再分发义务：引用 commons-text 时须保留 LICENSE 与 NOTICE、在文档中注明使用了 Apache Commons Text，可自由修改与商用，并享有 Apache-2.0 提供的专利授权，但不得使用 Apache 商标暗示官方背书。流程建议：将扫描命令固化为独立的 CI 步骤（固定 --license --copyright --package 三个插件），对每轮结果做差异比对以跟踪新增的复合表达式与未识别文件；对匹配得分低于 100 的条目、文档类文件与测试数据三类结果默认转人工复核，可配合 OpossumUI 完成判定留痕。

评价表格：

考核标准	得分
（1）报告格式规范、语言通顺（10%）；	
（2）质量标准分析合理（10%）；	
（3）测试方法分析全面、合理（20%）；	
（4）测试风险分析全面、合理（20%）；	
（5）测试总体测试策略全面、合理（30%）	
（6）测试充分性判断标准合理（10%）	